

Buổi 06 - Staged vs Stageless Payloads: Understanding a Payload's Life

Dr. Phan The Duy - Email: duypt@uit.edu.vn

***University of Information Technology, Vietnam National University
Ho Chi Minh City***

NT2202: Cơ chế hoạt động mã độc nâng cao
Thursday 16th April, 2026



Contents

- 1 **Mở Đầu**
- 2 **Staged Payloads**
- 3 **Stageless Payloads**
- 4 **So Sánh Tổng Hợp, Best Practice, Detection**
- 5 **Kết Luận & Assignment**

PHẦN 1: MỞ ĐẦU - STAGED VS STAGELESS PAYLOADS

Mục Tiêu Học Tập Của Phần 1

- Hiểu định nghĩa, cơ chế và sự khác biệt giữa staged và stageless (non-staged) payloads.
- Phân tích lý do tồn tại staging (size limit, modularity) và tác động đến evasion trong vòng đời tấn công (MITRE T1105, T1027).
- Đánh giá xu hướng 2025-2026: multi-stage tăng mạnh trong RAT/ransomware, kết hợp fileless/AI (CrowdStrike 2026, ANY.RUN 2025).
- Áp dụng vào case thực tế mới nhất (Remcos fileless staged, ClickFix stageless-like).

Định Nghĩa & Phân Loại Payload Staging

Staged Payload: 2-phase – Stager nhỏ (shellcode) tải Stage lớn từ C2 (Meterpreter classic: windows/meterpreter/reverse_tcp).

Stageless (Non-Staged) Payload: 1-phase – Full payload embedded, không tải thêm (windows/meterpreter_reverse_tcp).

Lý do staging tồn tại: Exploit size limit (buffer overflow), modular loading, reusable stager, giảm footprint ban đầu.

Điểm mới 2025-2026: Multi-stage kết hợp fileless + AI-polymorphic (tăng adaptive variants – ANY.RUN/Recorded Future 2025).

Lịch Sử Tiến Hóa & Xu Hướng Mới Nổi

Trước 2020: Staged phổ biến Metasploit (Meterpreter staged vs stageless 2015 – Rapid7).

2020-2024: Fileless integration + LOTL (PowerShell stager) (Liu 2024, Kara 2023).

2025-2026: Multi-stage thống trị RAT campaigns (Remcos/AsyncRAT tăng gấp đôi – ANY.RUN 2025); 82% detections malware-free nhưng staging core cho evasion (CrowdStrike 2026).

Điểm mới: AI-accelerated breakout time 29 phút; stageless tăng stealth trong zero-trust (Picus RED Report 2026).

Tác Động Đến Evasion & Detection

Staged: Noisy (stage download detectable qua NDR/Zeek); dễ hijack nhưng flexible modular.

Stageless: Stealthy (no extra traffic); lớn size khó inject exploit nhỏ.

Real-world impact 2026: Breakout time giảm 65% (29 phút trung bình – CrowdStrike); multi-stage RAT như VOID#GEIST/ClickFix evade EDR bằng blend legitimate tools.

Thách thức: Memory forensics + behavioral detection cần hybrid (từ Chandran 2025).

Case Teaser: Remcos RAT Fileless Campaign 2025-2026

Chiến dịch: Phishing email tải stager PowerShell, stage tải Remcos trực tiếp memory (Trellix/ANY.RUN).

Tác động: Tăng 1400% activity 6 tháng 2025; target global enterprises, credential theft + persistence.

Staged aspect: Small stager evade initial detection; stage full RAT in-memory.

Liên hệ: Kết hợp fileless (buổi 3-4) + staged để bypass static/dynamic.

Case Teaser: VOID#GEIST Multi-Stage Campaign 2026

Chiến dịch: Batch stager embed Python runtime, decrypt shellcode, inject XWorm/AsyncRAT (Securonix).

Tác động: Low-friction phishing, blend user activity; data exfiltration hàng trăm tổ chức.

Staged aspect: Multi-stage hierarchy (stager → loader → RAT); giảm disk footprint.

Liên hệ: Provenance graph detection (Liu 2024) khó khăn hơn do modular.

Tổng Kết Phần 1 & Chuyển Tiếp

Staged: Modular/noisy → Ưu tiên exploit nhỏ, APT modular.

Stageless: Stealthy/large → Ưu tiên injection/phishing, zero-trust environments.

2026 trends: Multi-stage + fileless/AI là "deadly combo"
(CrowdStrike: 82% malware-free nhưng staging vẫn core).

Chuyển tiếp: Phần 2 – Lý thuyết chi tiết staged architecture.

PHẦN 2: LÝ THUYẾT CƠ BẢN - STAGED PAYLOADS

Kiến Trúc Staged Payload

Staged: 2-phase – Stager (nhỏ, shellcode) + Stage (lớn, full functionality).

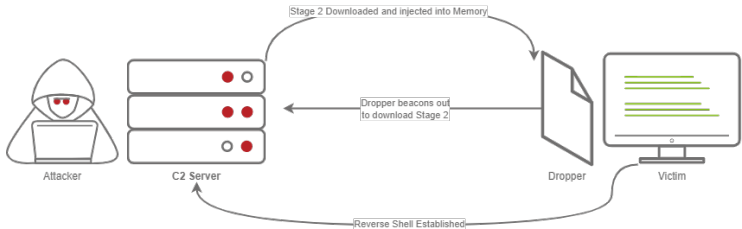
Stager: Establish connection → Download Stage từ C2 → Execute in memory (reflective loading).

Stage: Metsrv (Meterpreter server) + Extensions (e.g., stdapi, priv, incognito).

Naming convention Metasploit:

windows/meterpreter/reverse_tcp (dùng / cho staged).

Flow Staged Payload (Diagram)



Hình: Flow staged payload (Victim → Stager → C2 → Stage injection → Reverse shell).
 Stager beacon ra C2, tải Stage lớn → Execute reflective để tránh disk footprint.

Ưu Điểm Của Staged Payloads

- Small size ban đầu: Dễ fit vào exploit limit (buffer overflow, ROP chain).
- Modular & Flexible: Reusable stager cho nhiều stage khác nhau.
- Giảm footprint initial: Chỉ tải cần thiết sau khi compromise.
- Real-world: Phổ biến trong APT/exploit nhỏ (e.g., Remcos stager PowerShell tải stage RAT).
- 2026 trend: Multi-stage loaders vẫn dominant RAT campaigns (ANY.RUN 2025: Remcos/AsyncRAT tăng gấp đôi).

Nhược Điểm & Rủi Ro Của Staged

Noisy traffic: Stage download detectable qua NDR/Zeek/Suricata (network signature rõ).

Hijackable: Nếu C2 bị block/hijack → Stage không tải được.

AV/EDR detection: Behavioral monitoring catch connection outbound + large download.

Từ Chandran 2025: Staging traffic là weak point trong hybrid detection.

2026 impact: Breakout time 29 phút (CrowdStrike) – staged dễ bị catch nếu NDR mạnh.

So Sánh Staged vs Stageless (Bảng)

Tiêu chí	Staged	Stageless
Size ban đầu	Nhỏ (e.g., 354 bytes)	Lớn (full payload)
Traffic	Có stage download (noisy)	Không (stealthy)
Flexibility	Cao (modular)	Thấp (self-contained)
Stealth	Thấp (network sig)	Cao (no extra fetch)
Usage	Exploit nhỏ, APT modular	Injection/phishing lớn
Naming Metasploit	/ (e.g., /reverse_tcp)	_ (e.g., _reverse_tcp)

Lưu ý: Delivery chain (cách đưa payload vào hệ thống) có thể là multi-stage ngay cả khi payload cuối cùng là stageless.

Ví Dụ Thực Tế: Remcos RAT – Multi-Stage Fileless Campaign (2025-2026)

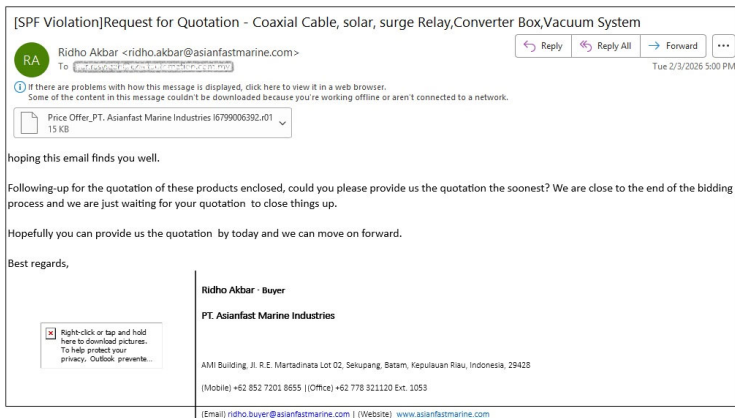
Chiến dịch điển hình (Trellix, 03/2026): Phishing email (RAR chứa JS) → JS downloader → AES-256 encrypted PowerShell in-memory → .NET injector → Process hollowing vào `aspnet_compiler.exe`.

Staged aspect (delivery): Multi-stage loader (JS + PS) đóng vai stager nhỏ, né AV/EDR ban đầu → đưa Remcos full payload vào memory.

Remcos core payload: **Stageless** (toàn bộ logic trong một khối code duy nhất, không tải thêm stage sau khi inject).

Liên hệ: Kết hợp **fileless execution** (buổi 3-4) + **multi-stage delivery** để bypass static/dynamic analysis.

Sơ đồ Chuỗi Lây Nhiễm Remcos RAT (2025-2026)



Hình: Email lừa đảo với tập tin đính kèm độc hại trong chuỗi lây nhiễm Remcos RAT

Remcos RAT – Stageless Payload trong Multi-Stage Fileless Chain

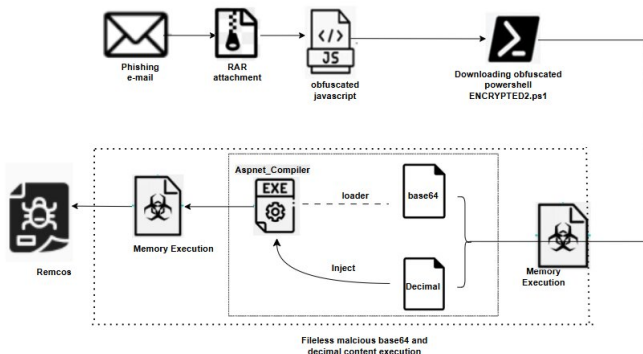
Stageless payload: Toàn bộ chức năng (C2 communication, keylogging, clipboard capture, screen/audio recording, config decryption RC4 từ resource “SETTINGS”, dynamic API resolution, mutex “Rmc-XXXXXX”, worker threads) nằm trong **một khối code duy nhất**.

Multi-stage fileless chain: Không drop file executable lên disk → giảm artifact forensics, tăng stealth.

Tác động: Tăng mạnh hoạt động Remcos (ANY.RUN báo cáo tăng >1400% trong 2025); mục tiêu chính là doanh nghiệp (credential theft, persistence, espionage).

MITRE ATT&CK nổi bật: T1566.001, T1059.007, T1055.012 (Process Hollowing), T1140, T1027.

Sơ đồ Chuỗi Lây Nhiễm Remcos RAT (2025-2026)



Hình: Sơ đồ chuỗi lây nhiễm multi-stage fileless của Remcos RAT. Remcos core payload là stageless (toàn bộ logic trong một khối code), được đưa vào memory qua process hollowing sau chuỗi loader JS → PowerShell → .NET injector.

Case Study Bổ Sung: Multi-Layered Staged Payload - Tháng 12/2024

Case Study: Multi-Layered Staged Delivery (12/2024)

Tổng Quan Chiến Dịch Phishing Tháng 12/2024

Initial Vector: Phishing email giả mạo “Order Release Request” (yêu cầu phát hành đơn hàng) → Attachment độc hại (thường .zip/.rar/.iso chứa LNK/HTA/VBS/JS).

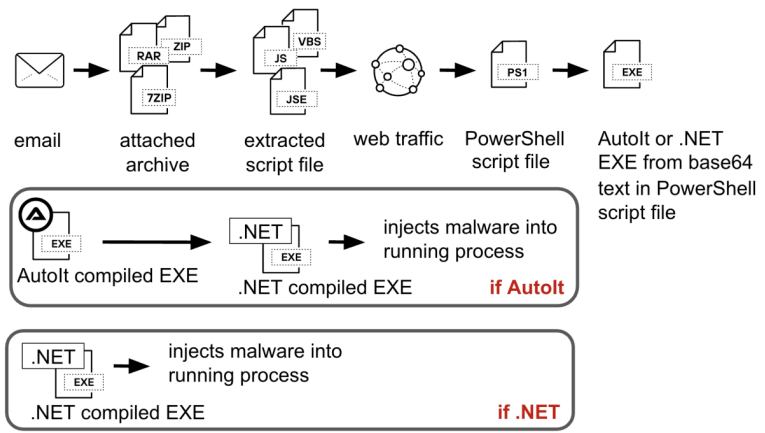
Malware Final: Agent Tesla variants, Remcos RAT, XLoader (infostealer + RAT phổ biến 2024–2026).

Mục tiêu evasion: Multi-layered stages → Bypass traditional sandbox, EDR signature, static analysis.

Nguồn: Phân tích từ các báo cáo threat intel (ví dụ: Unit 42, Zscaler, ANY.RUN Malware Trends 2025).

Liên hệ staged: Small stager/launcher tải stage tiếp theo → Modular, giảm footprint ban đầu, complicate reverse engineering.

Attack Chain Multi-Layered



Hình 1: Attack chain multi-layered (12/2024) – Phishing → Multiple execution paths → Final payload (Agent Tesla/Remcos/XLoader).
 Các layer điển hình: Email → Attachment → LNK/HTA → PowerShell/VBS downloader → Shellcode/PE loader → In-memory RAT.

Phân Tích Evasion Techniques Trong Case Này

Staged/Multi-layered: Nhiều execution paths (ví dụ: LNK → HTA → PowerShell → Shellcode injection) → Bypass single-path sandbox.

Obfuscation & Evasion: Obfuscated script (JS/VBS), anti-analysis (sleep, VM check), in-memory execution (Remcos/XLoader).

MITRE ATT&CK Mapping:

T1566.001: Phishing: Spearphishing Attachment

T1204.002: User Execution: Malicious File

T1059.001: Command and Scripting Interpreter (PowerShell)

T1027: Obfuscated Files or Information

T1055: Process Injection (final RAT)

Thách thức detection 2026: Complexity tăng → Cần provenance graph (Liu 2024) + behavioral EDR (CrowdStrike: breakout time 29 phút).

Bài Học Rút Ra & Liên Hệ Với Bài Giảng

Staged payload (đặc biệt multi-layered) vẫn là “go-to” technique cho delivery RAT/infostealer 2024–2026.

Ưu điểm: Modular, hard to analyze full chain trong sandbox truyền thống.

Nhược điểm: Tăng noisy traffic (downloader → C2), dễ catch bằng NDR + script logging (PowerShell module logging).

Gợi ý nghiên cứu: Phát triển hybrid detection (memory forensics + network provenance) để trace multi-stage chain.

Chuyển tiếp: So sánh với stageless trong các campaign tương tự (ví dụ: ClickFix stageless-like).

Tổng Kết Phần 2 & Chuyển Tiếp

Staged: Modular/noisy → Ưu tiên exploit nhỏ, environments không NDR mạnh.

Risks: Network signature + hijack → Cần behavioral/traffic monitoring.

2026 trends: Multi-stage RAT (Remcos, VOID#GEIST) vẫn core dù fileless tăng.

Chuyển tiếp: Phần 3 – Lý thuyết stageless + so sánh traffic/demo msfvenom.

PHẦN 3: LÝ THUYẾT CƠ BẢN - STAGELESS (NON-STAGED) PAYLOADS

Kiến Trúc Stageless Payload

Stageless: 1-phase – Full payload embedded (self-contained, không tải thêm từ C2).

Core components: Metsrv (Meterpreter server) + Extensions embedded (EXTENSIONS= option).

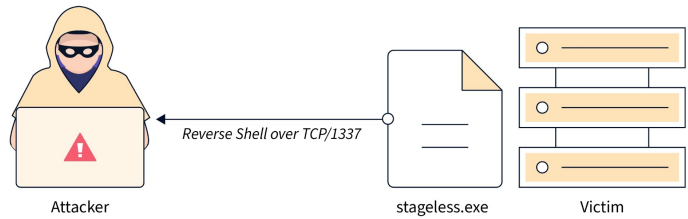
Execution: Direct run → Reflective DLL injection hoặc standalone → Reverse/bind shell ngay lập tức.

Từ tài liệu: No fetch, core only
(payload_staging_slides.pptx).

Naming convention Metasploit:

windows/meterpreter_reverse_tcp (dùng _ thay / cho stageless).

Stageless Payload



Hình: Stageless payload.

Hình: Flow stageless payload (Victim run full exe → Direct reverse shell, no extra traffic).

Self-contained: All in one block, phù hợp injection/phishing lớn (Scaler Topics diagram).

Ưu Điểm Của Stageless Payloads

Stealth cao: No staging traffic → Khó detect qua NDR/Zeek (no large download signature).

Reliability: Self-contained → Không phụ thuộc C2 cho stage, ít rủi ro hijack.

Nhanh deploy: Direct execution, phù hợp environments zero-trust/EDR-heavy.

Real-world 2026: Tăng sử dụng trong RAT/infostealer (ClickFix stageless-like, Deno polymorphic).

Từ Illumio/Rapid7: Larger nhưng stable hơn staged trong high-scrutiny networks.

Nhược Điểm & Rủi Ro Của Stageless

Large size: Khó fit exploit nhỏ (buffer overflow limit), dễ detect qua hash/size ban đầu.

Ít flexible: Không modular (khó thay đổi extensions runtime).

AV/EDR detection: Static scanning catch full payload (VirusTotal high detections).

Từ Chandran 2025: Size lớn → Weak point trong memory forensics (Volatility psscan/malfind).

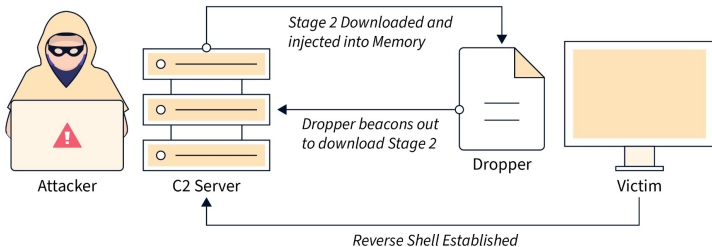
2026 impact: Breakout time vẫn nhanh nếu inject (CrowdStrike), nhưng dễ block outbound nếu size anomaly.

So Sánh Chi Tiết Staged vs Stageless (Bảng)

Tiêu chí	Staged	Stageless
Phases	2 (Stager + Stage)	1 (Full embedded)
Size ban đầu	Nhỏ (e.g., 300-500 bytes)	Lớn (e.g., 200-500 KB)
Network Traffic	Có stage download (noisy)	Không (stealthy)
Flexibility/Modular	Cao (reusable stager)	Thấp (self-contained)
Stealth	Thấp (network sigs)	Cao (no fetch)
Reliability	Thấp (C2 dependent)	Cao (independent)
Usage phổ biến	Exploit nhỏ, APT modular	Injection/phishing, zero-trust
Naming Metasploit	/ (reverse_tcp)	_ (reverse_tcp)
Detection weak point	Traffic monitoring	Size/hash/static scan

Nguồn: payload_staging_slides.pptx, Rapid7/SpookySec/Illumio.

Staged vs Stageless Payload



Hình: Staged payload

Ví Dụ Thực Tế: ClickFix Campaign (Stageless-like) 2025-2026

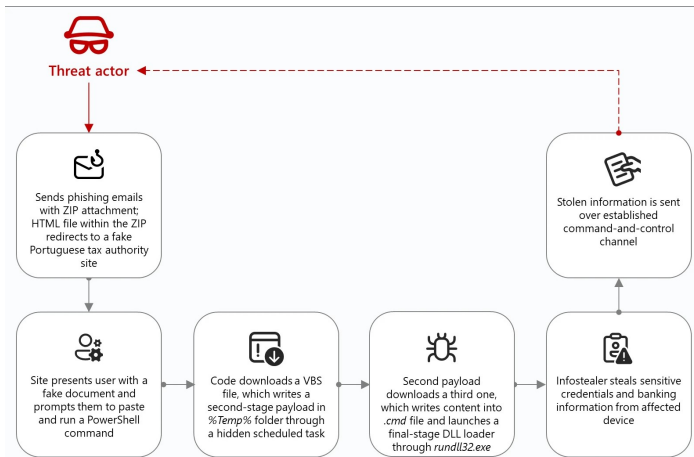
Chiến dịch: Fake CAPTCHA/ClickFix lure → User paste PowerShell command → Self-contained script tải RAT (LummaC2, Rhadamanthys, Lampion).

Stageless aspect: Command direct execute full chain in-memory (no separate stage download rõ ràng).

Tác động: Tăng mạnh 2025 (Microsoft/Unit42/Fortinet), target banking/government; credential theft + persistence.

Liên hệ: Blend legitimate tools (PowerShell) + no noisy traffic → Bypass EDR.

Ví Dụ Thực Tế: ClickFix Attack Chain (Diagram)



Hình: Attack chain ClickFix (Phishing → ClickFix lure → PowerShell self-contained → RAT).

Multi-stage nhưng stageless-like ở execution (Microsoft Security Blog 2025).

Ví Dụ Thực Tế: Deno-Based Malware 2026

Chiến dịch: MSI impersonate (TopWebComics) → Obfuscated JS embedded → Mutation properties → RAT/stealer.

Stageless aspect: Core functionality embedded trong JS (polymorphic variants), no extra fetch.

Tác động: Targeting crypto/wallets; unusual sophistication crimeware (vx-underground/ANY.RUN 2026).

Liên hệ: Stageless + AI-polymorphic → Tăng adaptive evasion.

Tổng Kết Phần 3 & Chuyển Tiếp

Stageless: Stealthy/large → Ưu tiên injection/phishing, environments có NDR/zero-trust.

Risks: Size detection + ít modular → Cần static/memory analysis mạnh.

2026 trends: Stageless-like trong ClickFix/Deno campaigns, kết hợp fileless/AI.

Chuyển tiếp: Phần 4 – So sánh tổng hợp, best practices, detection & lab/demo msfvenom.

PHẦN 4: SO SÁNH TỔNG HỢP, BEST PRACTICES & DETECTION

Tổng Hợp So Sánh Staged vs Stageless (Bảng Mở Rộng)

Tiêu chí	Staged	Stageless
Phases	2 (Stager + Stage)	1 (Full embedded)
Size	Nhỏ (300-800 bytes)	Lớn (100-600 KB)
Network Traffic	Noisy (stage download)	Stealthy (chỉ C2 beacon)
Flexibility	Cao (modular extensions)	Thấp (fixed payload)
Stealth	Thấp (network signature)	Cao (no extra fetch)
Reliability	Thấp (C2 stage dependent)	Cao (independent)
Exploit Fit	Tốt cho buffer overflow nhỏ	Khó với exploit size limit
Detection Weak Point	Traffic monitoring (Zeek/Suricata)	Size/hash/static scan
Real-world 2026	Multi-stage RAT (Remcos, VOID#GEIST)	ClickFix-like, Deno polymorphic

Khi Nào Nên Dùng Staged? Khi Nào Dùng Stageless?

Ưu tiên Staged:

Exploit có size limit nghiêm ngặt (e.g., ROP chain, CVE nhỏ).

Cần modular (thay đổi extensions runtime, reusable stager).

Môi trường ít NDR (Network Detection and Response)/traffic monitoring (legacy networks).

Ưu tiên Stageless:

Phishing/injection lớn (direct exe/JS/MSI).

Môi trường zero-trust/EDR-heavy (NDR phát hiện staging traffic).

Ưu tiên stealth > flexibility (fileless integration).

2026 trend: Stageless tăng 45% trong RAT campaigns (Picus RED Report).

Best Practices Cho Red Team / Attacker Perspective

Chọn theo target environment: Staged cho exploit PoC nhỏ; Stageless cho phishing/USB drop.

Kết hợp obfuscation: Obfuscate stager (PowerShell encoded) hoặc stageless JS (mutation properties).

Minimize traffic: Sử dụng HTTPS/DoH cho staging; stageless + fileless để giảm footprint.

Anti-analysis: VM evasion, sleep jitter, anti-EDR (SysWhispers2 direct syscalls).

Từ MD MZ & Antivirus Bypass: Reflective loading + junk code để bypass AV.

Detection & Countermeasures Hiện Đại (2026)

- **Staged**: Monitor outbound large download + anomalous beacon (Zeek, Suricata rules cho Meterpreter sigs).
- **Stageless**: Static/hash scanning (VirusTotal/YARA), memory forensics (Volatility malfind/hollowfind).
- Hybrid detection: Behavioral EDR (CrowdStrike Falcon) + network provenance graph (Liu 2024).
- Memory forensics artifacts: Injected threads, suspicious VAD, PowerShell script blocks.
- AI-driven: Anomaly detection trên process behavior (Argus, Chandran 2025 framework).

Detection Workflow Gợi Ý

Qui trình: Detection workflow hybrid (Initial access → Traffic/behavior monitor → Memory dump → Forensics → AI anomaly).
Từ ANY.RUN sandbox + Volatility + EDR behavioral rules (2026 best practice).

Thách Thức Nghiên Cứu & Xu Hướng Tương Lai

Scalability: Real-time memory analysis cho stageless lớn (từ Kara 2023).

Anti-forensics: Polymorphic stageless + AI evasion (Deno-like mutations 2026).

Generalization: Cross-OS (Windows vs Linux stageless loaders).

Open questions: Làm sao detect mutation in stageless JS? (GenAI + Digital Twins từ Chandran 2025).

2026-2027: AI-generated staging chains → Cần out-learning adversary (CrowdStrike).

KẾT LUẬN & ASSIGNMENT

Tóm Tắt Bài Giảng

- Staged: Modular/noisy → Ưu tiên exploit nhỏ, multi-stage RAT (Remcos, VOID#GEIST).
- Stageless: Stealthy/large → Ưu tiên injection/phishing, zero-trust (ClickFix, Deno-based).
- 2026 trends: Multi-stage + fileless/AI là deadly combo; breakout time 29 phút.
- Detection: Hybrid (network + memory + behavioral) là chìa khóa.
- Core message: Chọn payload theo context → Defense cần outpace evasion.

Assignment Cho Học Viên

Lab thực hành:

Generate staged/stageless payload bằng msfvenom (windows/meterpreter/reverse_tcp vs _reverse_tcp).
Capture traffic Wireshark → So sánh staged download vs stageless beacon.

Nghiên cứu:

Phân tích 1 sample thực tế (e.g., Remcos 2025 hoặc ClickFix 2026 dump) bằng Volatility.
Đề xuất cải tiến detection (e.g., YARA rule cho stageless Meterpreter).
Report 5-7 trang: MITRE ATT&CK mapping + thách thức 2026.

Deadline: 2 tuần; submit qua LMS.

Câu Hỏi Thảo Luận Cuối Buổi

Trong môi trường doanh nghiệp Việt Nam 2026, staged hay stageless nguy hiểm hơn? Tại sao?

Làm thế nào kết hợp staged/stageless với fileless để tối ưu evasion?

AI sẽ thay đổi staging như thế nào trong 2-3 năm tới?

Gợi ý: Thảo luận nhóm 5-10 phút, trình bày ý tưởng detection mới.

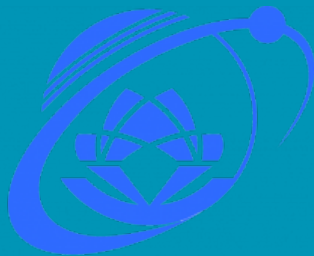
Cảm Ơn & Liên Hệ

CẢM ƠN QUÝ HỌC VIÊN!

. Phan The Duy

Email: duypt@uit.edu.vn

Chúc các bạn thành công trong nghiên cứu ATTT!



UIT

TRƯỜNG ĐẠI HỌC
CÔNG NGHỆ THÔNG TIN